

Governance Artifact

Proposal: sonarqube-gate-tool

Status: PROPOSED

Spec ID: `sonarqube-gate-tool`

Triggered by: OR&AA Resiliency Week demo feedback — 2026-04-08

Scope: `governance/hangar-ai-constitution/` (constitution repo) + `governance/hangar-ai-constitution-workflows/` (workshop repo)

Problem

1. SonarQube Has No Provisioning Tool in the Constitution

The constitution has `skill-sonarqube-compliance-gate.md` — a mature skill for reading gate results via API. But it assumes SonarQube is already running and configured. There is no canonical tool in the constitution that:

- Spins up a local SonarQube instance via Docker
- Provisions the "Hangar AI Constitution Gate" with all 9 conditions
- Creates a project and token in one command
- Is reusable by any team adopting the constitution (not just workshop participants)

Currently the only Docker setup exists inside the **workshop's** `sample-codebase/` — tightly coupled to the workshop exercises and the `aadventure-loyalty-platform` project. A team applying the constitution to their own codebase has no equivalent.

2. SonarQube Is Framed as Optional — It Is Not

During OR&AA Resiliency Week, the demo showed that the SonarQube dashboard is the **primary human engagement interface** in the agentic workflow. The agent does the work. The human stays engaged by watching the gate status — FAIL → PASS — on the dashboard. This is not a nice-to-have: it is the mechanism that keeps humans in the loop during agentic development.

The current `adoption.md` workflow has no SonarQube provisioning step. The application guide treated Docker as optional. This is architecturally wrong. Without the gate, the agentic workflow has no external, objective referee — the agent self-assesses, which the constitution explicitly forbids (see `skill-sonarqube-compliance-gate.md`: *"The same model that introduced a violation cannot be trusted to assess whether it is resolved"*).

3. No Constitutional Law for the Agentic Feedback Loop

The constitution has laws about test coverage (ENG-4.x), security (ENG-6.x), and complexity (ENG-3.x). But there is no law that explicitly governs the **agentic feedback loop** — the requirement that every phase of agentic development must have an external, human-visible compliance checkpoint before the agent may advance. This law is missing.

Solution

Workstream 1 — `tools/sonarqube-gate/` in the Constitution Repo

Create a reusable, project-agnostic SonarQube provisioning tool at:

```
governance/hangar-ai-constitution/tools/sonarqube-gate/
├─ docker-compose.yml      # SonarQube 10.7 Community + PostgreSQL 15 — project-agnostic
├─ provision.sh             # One command: start → wait → create gate → create token → write .sonar-token
├─ gate-config.json        # Machine-readable Hangar AI Constitution Gate definition (9 conditions)
└─ README.md               # Quick start, what it does, AA corporate SonarQube alternative
```

Key design principles:

- **Project-agnostic:** No hardcoded project keys. `provision.sh` accepts `--project-key` as argument.

- **Idempotent:** Safe to re-run. Gate already exists? Skip. Project already exists? Skip.
- **One command:** `./tools/sonarqube-gate/provision.sh --project-key my-service` — start to token in one step.
- **Token written to** `.sonar-token` at the path the caller specifies (default: `./sonar-token`). `.sonar-token` must be in `.gitignore`.
- **Gate definition versioned in** `gate-config.json` — single source of truth for all 9 conditions, readable by both humans and the `skill-sonarqube-compliance-gate` skill.

Gate conditions (from `gate-config.json`):

| Condition | Metric | Operator | Threshold | Classification | |---|---|---|---|---| | New violations | `new_violations` | GT | 0 | AA Baseline
 | | New coverage | `new_coverage` | LT | 80 | AA Baseline | | New duplication | `new_duplicated_lines_density` | GT | 3 | AA Baseline |
 | New hotspots reviewed | `new_security_hotspots_reviewed` | LT | 100 | AA Baseline | | Vulnerabilities | `vulnerabilities` | GT | 0 |
 HARD_BLOCK (ENG-6.1) | | Security rating | `security_rating` | GT | 1 | HARD_BLOCK (ENG-6.1) | | Blocker violations |
`blocker_violations` | GT | 0 | HARD_BLOCK (ENG-6.7) | | Overall coverage | `coverage` | LT | 80 | PHASE_GATE (ENG-4.6) | |
 Overall duplication | `duplicated_lines_density` | GT | 3 | WARNING (ENG-3.1) |

Workstream 2 — New Constitutional Law: ENG-12 Agentic Compliance Feedback Loop

Add a new section to `laws/engineering/` (new file: `agentic-feedback.md`) or amend `spec-driven-development.md`:

ENG-12.1 — Agentic Feedback Loop Law (NON-NEGOTIABLE)

"Every phase of agentic development MUST have an external, human-visible compliance checkpoint before the agent may advance to the next phase. The SonarQube Constitution Gate is the canonical external checkpoint. The agent proposes and implements; the human judges by the dashboard. No phase gate is complete without human review of the gate status. The agent MUST NOT auto-advance phases based on self-assessment."

ENG-12.2 — Dashboard-First Development

"The SonarQube dashboard MUST be open throughout every agentic development session. It is the objective source of truth — not the agent's assertions, not test output alone. The gate result is the contract between agent and human: FAIL means work continues; PASS means the human approves advancement."

ENG-12.3 — External Referee Law

"A model that introduced a violation is not permitted to assess whether the violation is resolved. Only an external gate — SonarQube, CI, or equivalent — may certify resolution. Self-reported compliance is not compliance."

Workstream 3 — Update `adoption.md` — Add "Provision the Gate" as Phase 2b

After `AGENTS.md` creation and before characterization tests, add:

Phase 2b: Provision the Constitutional Gate

```
# From your project root:
./path/to/hangar-ai-constitution/tools/sonarqube-gate/provision.sh \
  --project-key [your-project-key] \
  --token-path ./sonar-token
```

This step:

1. Starts Docker (SonarQube + PostgreSQL)
2. Waits for health
3. Creates the Hangar AI Constitution Gate
4. Creates your project
5. Writes `.sonar-token`
6. Runs baseline scan → establishes the FAIL state the agent will work toward

The dashboard URL (`http://localhost:9000`) should be opened and kept visible throughout the session. The FAIL state is the starting contract.

Workstream 4 — Update skill-sonarqube-compliance-gate.md

Add a "Prerequisites — Local Development" section showing two paths:

- 1. Corporate SonarQube (existing) — set SONARQUBE_TOKEN , SONARQUBE_URL , PROJECT_KEY env vars
- 2. Local Docker (new) — run tools/sonarqube-gate/provision.sh — token auto-written, URL is http://localhost:9000

Make explicit: the dashboard must be open. The skill is not just an API call — it is a human review checkpoint.

Workstream 5 — Update AGENTS.md

Add tools/sonarqube-gate/ alongside tools/constitution-lint/ in the project structure and governance tools table. Add the ENG-12.1 reference to the Non-Negotiable Laws section.

Workstream 6 — Update Application Guide

Restore Docker/SonarQube setup as Step 0b in exercises/application-guide.html — not optional, positioned as the human engagement interface:

"Step 0b: Provision the Constitutional Gate — This is what transforms the agentic workflow from best-effort into objectively governed. Keep the dashboard open throughout your session. The gate is the contract between you and the agent."

Reference tools/sonarqube-gate/ in the constitution repo (not the workshop's sample-codebase setup).

Deliverables

| # | Deliverable | Verifiable By | |---|---|---| | 1 | tools/sonarqube-gate/docker-compose.yml — project-agnostic | No hardcoded project keys; starts SonarQube + PostgreSQL | | 2 | tools/sonarqube-gate/provision.sh — idempotent one-command setup | Runs on a clean machine; writes .sonar-token ; gate created | | 3 | tools/sonarqube-gate/gate-config.json — machine-readable gate definition | All 9 conditions; version-controlled; matches skill conditions | | 4 | tools/sonarqube-gate/README.md — quick start | Step-by-step from zero to FAIL state in < 5 minutes | | 5 | New law ENG-12.1 (Agentic Feedback Loop) in constitution laws | Law ID present; NON-NEGOTIABLE status; dashboard-first framing | | 6 | New laws ENG-12.2 and ENG-12.3 in constitution laws | External referee law; dashboard-first law | | 7 | adoption.md — Phase 2b: Provision the Gate | Adoption workflow includes gate provisioning before characterization | | 8 | skill-sonarqube-compliance-gate.md — local Docker path added | Local + corporate paths both documented; dashboard-open requirement stated | | 9 | AGENTS.md — tools/sonarqube-gate/ in project structure + ENG-12.1 in non-negotiables | Visible in governance tools table | | 10 | exercises/application-guide.html — Step 0b restored with constitution tool reference | Docker setup present; framed as human engagement interface |

Out of Scope

- CI/CD SonarQube integration (separate proposal)
- Corporate SonarQube instance configuration (team-specific)
- Mutation testing gate conditions (mutation_score — separate skill-11)
- SonarQube cloud / SonarCloud support

Success Criteria

| Criterion | Target | |---|---| | Any team can run provision.sh and have a running gate | One command, clean machine, < 5 minutes | | Application guide reader can reach FAIL state on their own code | Without any workshop artifacts | | ENG-12.1 is in the Non-Negotiable Laws table in AGENTS.md | Visible on first read | | The agentic feedback loop law is cited in adoption.md Phase 2b | Every adoption runs the gate |

Law Citations

| Law | Relevance | |---|---| | ENG-12.1 (NEW) | Agentic Feedback Loop — gate is NON-NEGOTIABLE human checkpoint | | ENG-12.2 (NEW) | Dashboard-First Development — dashboard open throughout session | | ENG-12.3 (NEW) | External Referee — agent cannot self-certify compliance | | ENG-11.1 | Hangar SDD — this spec governs the work | | ENG-11.2 | Proposal Completeness |

